

2025



LAPORAN

HASIL PENILAIAN

**INSTRUMEN PENILAIAN KEMATANGAN
KEAMANAN SIBER (IKAS)**

Kilang Pertamina Internasional

PENDAHULUAN

I. Tujuan Kegiatan

Kegiatan ini bertujuan untuk mengetahui tingkat kematangan keamanan siber di lingkungan Kilang Pertamina Internasional yang selanjutnya disebut KPI. Dengan diketahuinya tingkat kematangan tersebut diharapkan KPI mendapatkan gambaran tentang kekuatan dan kelemahan yang perlu ditingkatkan pada setiap domain kerangka kerja keamanan siber sehingga KPI secara mandiri maupun bekerja sama dengan Badan Siber dan Sandi Negara (BSSN) dapat menyusun strategi peningkatan kematangan keamanan siber dengan lebih efektif.

II. Ruang Lingkup Kegiatan

Kegiatan yang dilaksanakan meliputi pemetaan dan penilaian aspek pengelolaan keamanan siber berdasarkan kerangka kerja perlindungan IIV yang merupakan konsep dasar yang digunakan sebagai pedoman dalam menyusun, menerapkan, dan mengomunikasikan, aktivitas pengelolaan keamanan siber pada lingkup sektor infrastruktur informasi vital. Domain kerangka kerja perlindungan IIV tersebut antara lain:

A. Identifikasi

Aspek ini mendukung kemampuan Penyelenggara IIV dalam memahami konteks bisnis, sumber daya, dan risiko yang mendukung penyelenggaraan IIV.

Aspek Identifikasi terdiri dari beberapa kategori yaitu:

1. mengidentifikasi peran dan tanggung jawab organisasi;
2. menyusun strategi, kebijakan, dan prosedur;
3. mengelola aset informasi;
4. menilai dan mengelola risiko keamanan siber; dan
5. mengelola risiko rantai pasok.

B. Proteksi

Aspek ini merupakan fungsi yang bertujuan untuk mendukung kemampuan Penyelenggara IIV dalam mencegah, membatasi, atau menahan dampak dari Insiden Siber.

Aspek Proteksi terdiri dari beberapa kategori yaitu:

1. mengelola identitas, autentikasi, dan kendali akses;
2. melindungi aset fisik;
3. melindungi data;
4. melindungi aplikasi;
5. melindungi jaringan; dan
6. melindungi sumber daya manusia.

C. Deteksi

Aspek Deteksi mendukung kemampuan Penyelenggara IIV dalam mengembangkan dan menerapkan aktivitas yang sesuai untuk memantau secara tepat waktu terjadinya peristiwa siber.

Aspek Deteksi terdiri dari beberapa kategori yaitu :

1. mengelola deteksi peristiwa siber;
2. menganalisis anomali dan peristiwa siber; dan
3. memantau peristiwa siber berkelanjutan.

D. Penanggulangan dan Pemulihan

Aspek Penanggulangan dan Pemulihan merupakan tahap reaktif setelah serangan yang tidak bisa diabaikan karena berdampak langsung terhadap keberlangsungan operasional.

Aspek Penanggulangan dan Pemulihan terdiri dari beberapa kategori yaitu :

1. menyusun perencanaan penanggulangan dan pemulihan insiden siber;
2. menganalisis dan melaporkan insiden siber;
3. melaksanakan penanggulangan dan pemulihan insiden siber; dan
4. meningkatkan keamanan setelah terjadinya insiden siber.

III. Metodologi

Penilaian kematangan keamanan siber dengan menggunakan instrumen IKAS dilaksanakan dalam dua tahap. Yang pertama adalah tahap “*self assessment*” berupa penilaian secara mandiri oleh tim KPI dengan mengisi instrumen IKAS disertai dengan menyiapkan bukti validasi pendukungnya. Sedangkan tahap kedua adalah tahap verifikasi yang dilakukan oleh Tim Verifikator BSSN dengan menggunakan metode wawancara/diskusi dan memverifikasi data dukung yang berkaitan untuk menilai kesesuaian dan ketepatan pengisian/penilaian mandiri instrumen IKAS yang telah dilakukan pada tahap pertama.

Hasil akhir penilaian IKAS diberikan dalam bentuk Tingkat Kematangan (Level Kematangan), Nilai Kematangan, dan bagan berbentuk radar yang menjelaskan perincian maturitas tiap kategori pada Domain Kerangka Kerja Keamanan Siber. Nilai Kematangan dalam rentang tertentu akan menentukan Level Kematangan. Terdapat lima Level Kematangan, yakni: Level 1: Level Awal; Level 2: Level Berulang; Level 3: Level Terdefinisi; Level 4: Level Terkelola; dan Level 5: Level Inovatif.

Rentang Nilai Kematangan yang menentukan masing-masing Level Kematangan adalah sebagai berikut:

- A. Level 1 (satu), dengan nilai kematangan pada rentang indeks 0 (nol) - 1,50 (satu koma lima nol) dinamakan level awal dengan kriteria :
 - 1. menggambarkan kondisi penerapan keamanan siber dalam tahap implementasi awal;
 - 2. penerapan keamanan siber belum memiliki prosedur yang terorganisir;
 - 3. penerapan keamanan siber bersifat informal;
 - 4. keamanan siber tidak dilakukan secara konsisten dan berkelanjutan; dan
 - 5. dokumen manajemen risiko dan dokumen kontrol belum disusun.
- B. Level 2 (dua), dengan dengan nilai kematangan pada rentang indeks 1,51 (satu koma lima satu) - 2,50 (dua koma lima nol) dinamakan level berulang dengan kriteria :

1. menggambarkan kondisi penerapan keamanan siber dalam tahap implementasi yang berulang;
 2. penerapan keamanan siber sudah memiliki prosedur yang terorganisir;
 3. penerapan keamanan siber bersifat informal;
 4. keamanan siber dilakukan secara berulang namun belum konsisten dan belum berkelanjutan; dan
 5. dokumen manajemen risiko dan dokumen kontrol sudah disusun namun belum ditetapkan.
- C. Level 3 (tiga), dengan nilai kematangan pada rentang indeks 2,51 (dua koma lima satu) - 3,50 (tiga koma lima nol) dinamakan level terdefinisi dengan kriteria :
1. menggambarkan kondisi penerapan keamanan siber dalam tahap implementasi yang telah terdefinisi dengan baik;
 2. penerapan keamanan siber telah terorganisir dengan jelas;
 3. penerapan keamanan siber bersifat formal;
 4. keamanan siber dilakukan secara berulang dan konsisten serta direviu secara berkala; dan
 5. dokumen manajemen risiko dan dokumen kontrol sudah disusun dan sudah ditetapkan.
- D. Level 4 (empat), dengan nilai kematangan pada rentang indeks 3,51 (tiga koma lima satu) - 4,50 (empat koma lima nol) dinamakan level terkelola dengan kriteria :
1. menggambarkan kondisi penerapan keamanan siber dalam tahap implementasi yang telah terkelola dengan baik.
 2. penerapan keamanan siber telah terorganisir dengan baik namun belum dilakukan proses otomatisasi;
 3. penerapan keamanan siber bersifat formal;
 4. keamanan siber dilakukan secara berulang dan implementasi perbaikan dilakukan berkelanjutan; dan

5. dokumen manajemen risiko dan dokumen kontrol sudah disusun dan sudah ditetapkan.
- E. Level 5 (lima), dengan nilai kematangan pada rentang indeks 4,51 (empat koma lima satu) - 5,0 (lima koma nol) dinamakan level inovatif dengan kriteria :
1. menggambarkan kondisi penerapan keamanan siber telah diimplementasikan secara optimal;
 2. penerapan keamanan siber telah terorganisir dengan baik dan telah dilakukan proses otomatisasi;
 3. penerapan keamanan siber bersifat formal;
 4. keamanan siber dilakukan secara berulang dan konsisten serta telah terintegrasi;
 5. keamanan siber menjadi bagian budaya organisasi secara menyeluruh; dan
 6. dokumen manajemen risiko dan dokumen kontrol sudah ditetapkan.

IV. Pelaksanaan Kegiatan

Pengisian setiap pertanyaan dari instrumen IKAS secara mandiri oleh Tim dari KPI. Selanjutnya verifikasi terhadap hasil penilaian mandiri instrumen IKAS tersebut dilaksanakan pada 28 s.d. 31 Oktober 2025. Adapun nama-nama dari tim verifikator BSSN sebagai berikut:

1. Reska Riskiyani, S.ST., Manggala Informatika Ahli Muda pada Direktorat Keamanan Siber dan Sandi Energi dan Sumber Daya Alam, Deputi Bidang Keamanan Siber dan Sandi Perekonomian.
2. Wahyu Achmad Fadiel, S.Tr.TP., Sandiman Ahli Pertama pada Direktorat Keamanan Siber dan Sandi Energi dan Sumber Daya Alam, Deputi Bidang Keamanan Siber dan Sandi Perekonomian.
3. Sarip Hidayat, S.Kom., Analis Kebijakan Ahli Pertama Direktorat Keamanan Siber dan Sandi Energi dan Sumber Daya Alam, Deputi Bidang Keamanan Siber dan Sandi Perekonomian.

HASIL KEGIATAN

I. Informasi Instansi/Organisasi

Nama : PT Kilang Pertamina Internasional
Nomor Telp./ Fax : 021135
Surat Elektronik : kpi.cyber.security@pertamina.com
Alamat : Patra Jasa Office Tower Lantai 9, Jl. Gatot Subroto Kav. 32-34, Jakarta Selatan, 12950
Narahubung KPI : Jefri Hajrianda

II. Deskripsi Ruang Lingkup Penilaian

1. Ruang Lingkup Pengukuran:

☒ Organisasi Keseluruhan ☐ Regional, Kanwil, Cabang ☐ Unit Kerja ☐ Lainnya

2. Organisasi : PT Kilang Pertamina Internasional (KPI)

3. Fungsi Kerja/ Proses Bisnis:

PT Kilang Pertamina Internasional (PT KPI) adalah *Subholding Refining & Petrochemical* PT Pertamina (Persero) yang merupakan *strategic holding company*. PT KPI mengembangkan investasi dan menjalankan bisnis Pertamina terkait pengolahan minyak bumi serta bahan lainnya menjadi produk-produk bahan bakar, pelumasan, petrokimia dan farmasi yang bernilai tinggi serta pengembangan bisnis pengolahan dan petrokimia dalam rangka memenuhi kebutuhan produk olahan dan petrokimia sesuai perkembangan pasar.

Pada 13 November 2017 PT Kilang Pertamina Internasional (PT KPI) didirikan sebagai *strategic holding company* PT Pertamina (Persero) untuk menjalankan, mengendalikan, dan mengelola kegiatan investasi dan usaha terkait megaprojek pengolahan dan petrokimia.

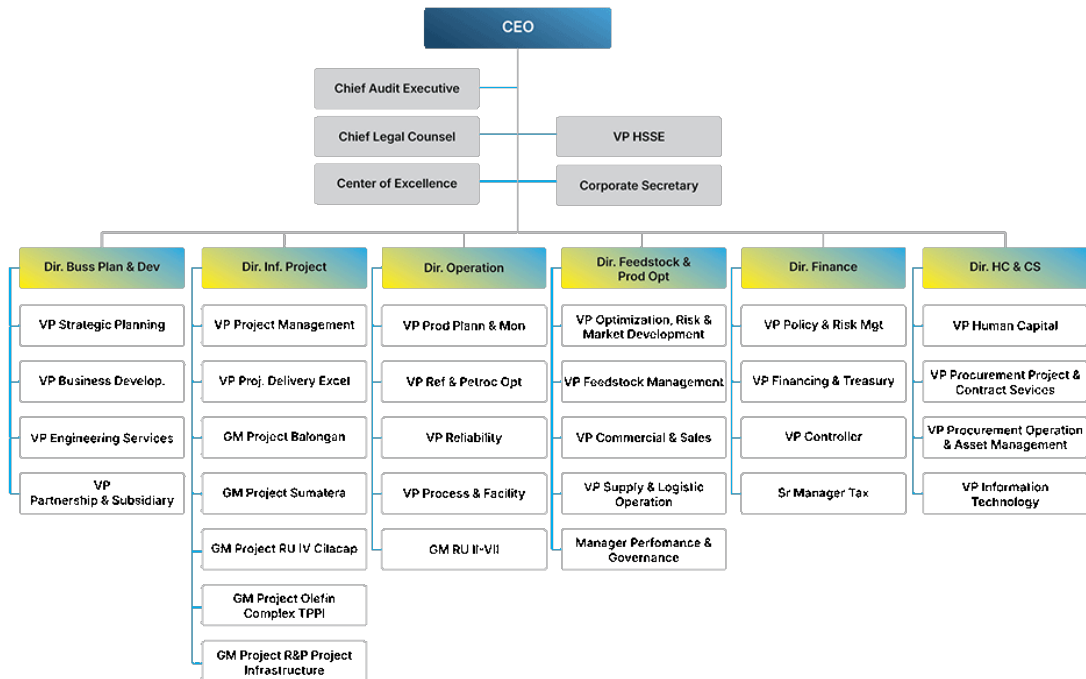
Pada 28 November 2017 didirikan PT Pertamina Rosneft Pengolahan dan Petrokimia (PT PRPP) sebagai Anak Perusahaan PT KPI untuk mengelola pembangunan proyek New Grass Root Refinery (NGRR) Tuban yang merupakan proyek kerja sama antara PT Pertamina (Persero) dan Rosneft Oil Company.

PT KPI mendirikan kembali satu anak perusahaan pada 7 Mei 2019, yaitu PT Kilang Pertamina Balikpapan (PT KPB), yang bertujuan untuk mengelola pembangunan Proyek Refinery Development Master Plan (RDMP) RU V Balikpapan dan dipersiapkan untuk menjadi perusahaan patungan bekerja sama dengan mitra.

Pada bulan Juni 2020, PT KPI semakin berkembang perannya selain mengelola proyek-proyek infrastruktur juga pengembangan bisnis pengolahan dan petrokimia serta mengelola kilang-kilang pengolahan & petrokimia yang sebelumnya dikelola oleh PT Pertamina (Persero) yaitu Refinery Unit II Dumai, Refinery Unit III Plaju, Refinery Unit IV Cilacap, Refinery Unit V Balikpapan, Refinery Unit VI Balongan dan Refinery Unit VII Sorong.

Perubahan peran tersebut ditandai dengan pengukuhan PT Kilang Pertamina Internasional sebagai Subholding Refining & Petrochemical sebagai bagian dari pembentukan Holding Migas. Perubahan peran ini, diikuti dengan pengangkatan Dewan Komisaris dan Direksi PT KPI yang baru.

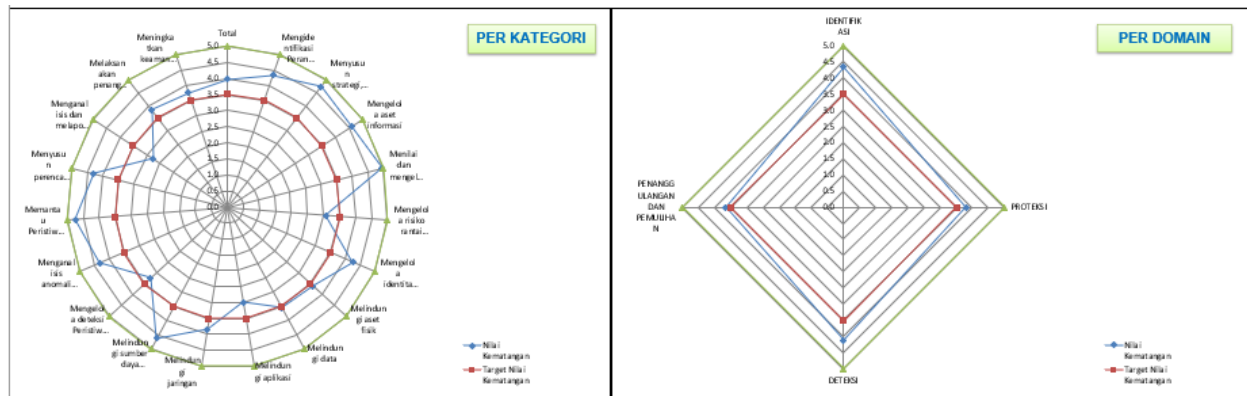
Dalam menjalankan bisnisnya, PT Kilang Pertamina Internasional didukung oleh Sumber Daya Manusia yang kompeten dengan susunan struktur organisasi yang dapat dilihat pada bagan berikut:



III. Hasil Penilaian IKAS

Berdasarkan hasil wawancara dan diskusi dalam rangka verifikasi pengisian Instrumen IKAS tahun 2025 diperoleh hasil sebagai berikut:

Tingkat Kematangan Keamanan Siber		2025				Kategori Tingkat Kematangan Keamanan Siber
		Target Nilai Kematangan	Nilai Kematangan	Nilai Kematangan per-Domain	Kategori Tingkat Kematangan per-Domain	
Total		3.51	3.98			
IDENTIFIKASI	Mengidentifikasi Peran dan tanggung jawab organisasi	3.51	4.33	4.34	Level 4 - Terkelola	
	Menyusun strategi, kebijakan, dan prosedur Keamanan Siber	3.51	4.75			
	Mengelola aset informasi	3.51	4.60			
	Menilai dan mengelola risiko Keamanan Siber	3.51	4.96			
	Mengelola risiko rantai pasok	3.51	3.07			
PROTEKSI	Mengelola identitas, autentikasi, dan kendali akses	3.51	4.25	3.81	Level 4 - Terkelola	
	Melindungi aset fisik	3.51	3.60			
	Melindungi data	3.51	3.54			
	Melindungi aplikasi	3.51	3.00			
	Melindungi jaringan	3.51	3.86			
DETEKSI	Melindungi sumber daya manusia	3.51	4.62	4.11	Level 4 - Terkelola	
	Mengelola deteksi Peristiwa Siber	3.51	3.25			
	Menganalisis anomali dan Peristiwa Siber	3.51	4.33			
PENANGGULANGAN DAN PEMULIHAN	Memantau Peristiwa Siber berkelanjutan	3.51	4.75	3.65	Level 4 - Terkelola	
	Menyusun perencanaan penanggulangan dan pemulihan Insiden	3.51	4.30			
	Menganalisis dan melaporkan Insiden Siber	3.51	2.75			
	Melaksanakan penanggulangan dan pemulihan Insiden Siber	3.51	3.83			
	Meningkatkan keamanan setelah terjadinya Insiden Siber	3.51	3.75			



Gambar Hasil Verifikasi Tingkat Kematangan Instrumen IKAS KPI

Berdasarkan penilaian instrumen IKAS tersebut diperoleh bahwa:

Total Score Nilai Kematangan: 3,98

Sehingga dengan Nilai Kematangan tersebut dapat ditentukan bahwa Level Kematangannya ada pada:

Tingkat Kematangan: Level 4

Dengan demikian, secara kualitatif dapat digambarkan bahwa penerapan keamanan siber organisasi saat ini sudah terorganisir, konsisten, dan dilakukan reviu berkala, yang berarti penerapannya sudah bersifat formal dan diawasi secara rutin. Organisasi telah berhasil melampaui Target Nilai Kematangan yang ditetapkan (3.51) dengan pencapaian nilai total 3.98. Meskipun implementasi sudah berada di level terkelola, namun belum mencapai level optimal, sehingga masih ada ruang untuk perbaikan lebih lanjut dalam pengelolaan dan proses otomatisasi baik dalam manajemen maupun keamanan yang bersifat teknis.

IV. Kekuatan/ Kematangan

Berdasarkan hasil verifikasi penilaian kematangan keamanan siber, dapat disimpulkan kondisi kekuatan keamanan siber pada KPI adalah sebagai berikut:

A. Domain Identifikasi

1. Kategori mengidentifikasi peran dan tanggung jawab organisasi

Mengidentifikasi peran dan tanggung jawab dalam organisasi memiliki fungsi penting untuk menunjang efektivitas dan efisiensi tugas dan proses bisnis organisasi dikarenakan dijalankan oleh pihak yang tepat. Risiko celah keamanan akibat duplikasi kerja atau kekosongan tanggung jawab dapat dihindari. Pembagian peran yang jelas dapat mempermudah koordinasi antar unit serta mempercepat pengambilan keputusan. Selain itu, struktur tanggung jawab yang tertata dengan baik dapat menciptakan lingkungan kerja yang aman, terkontrol, dan siap menghadapi berbagai risiko keamanan secara lebih efektif.

Kategori kegiatan mengidentifikasi peran dan tanggung jawab organisasi terdiri atas subkategori kegiatan menetapkan dan mengomunikasikan prioritas untuk misi, tujuan, dan kegiatan perlindungan IIV di organisasi; mengidentifikasi ketergantungan organisasi dengan pihak terkait lainnya; dan mengidentifikasi dan mengomunikasikan peran organisasi di dalam sektor IIV.

Adapun kekuatan yang dimiliki KPI pada kategori mengidentifikasi peran dan tanggung jawab organisasi antara lain:

- a. Organisasi sudah menetapkan dan mengomunikasikan prioritas untuk misi, tujuan, dan kegiatan pengamanan sistem elektronik.
- b. Organisasi mengidentifikasi ketergantungan organisasi dengan pihak terkait lainnya.
- c. Organisasi mengidentifikasi dan mengomunikasikan peran organisasi di dalam sektor sistem elektronik.

2. Kategori menyusun strategi, kebijakan, dan prosedur keamanan siber

Penyusunan strategi, kebijakan, dan prosedur keamanan siber dalam organisasi bertujuan membangun kerangka kerja yang terarah dan terstruktur serta mendukung pencapaian tujuan organisasi secara efektif. Penyusunan strategi keamanan siber dilakukan dengan menetapkan visi misi ataupun tujuan penerapan keamanan siber serta penetapan rencana strategis dan langkah prioritas yang akan dilakukan. Pencapaian strategi didukung oleh penerapan kebijakan dan prosedur keamanan yang mengatur dan mengikat terhadap seluruh aspek di organisasi. Penyusunan strategi, kebijakan, dan prosedur akan membantu organisasi dalam mengurangi risiko, meningkatkan efisiensi, serta menjamin kepatuhan terhadap regulasi dan standar yang berlaku. Selain itu, dokumen-dokumen tersebut dapat menjadi dasar evaluasi dan perbaikan berkelanjutan dalam tata kelola organisasi. Dengan demikian, organisasi dapat beroperasi secara terstruktur, akuntabel, dan adaptif terhadap perubahan.

Kategori menyusun strategi, kebijakan, dan prosedur keamanan siber terdiri atas subkategori kegiatan menetapkan dan mengomunikasikan kebijakan keamanan siber di lingkungan Penyelenggara IIV; mengembangkan strategi untuk meningkatkan perlindungan terhadap IIV; menetapkan persyaratan yang dibutuhkan untuk mendukung operasional IIV pada semua keadaan; menetapkan kebijakan penggunaan aset informasi bagi pegawai dan pihak ketiga.

Adapun kekuatan yang dimiliki KPI pada kategori menyusun strategi, kebijakan, dan prosedur keamanan siber antara lain :

- a. Organisasi menetapkan dan mengomunikasikan kebijakan keamanan siber di lingkungan organisasi.
- b. Organisasi mengembangkan strategi untuk meningkatkan pengamanan terhadap sistem elektroniknya.
- c. Organisasi menetapkan persyaratan yang dibutuhkan untuk mendukung operasional sistem elektronik baik pada kondisi normal, jika terjadi insiden siber, dan paska insiden siber.

- d. Organisasi menetapkan kebijakan penggunaan aset informasi bagi pegawai dan pihak ketiga.

3. Kategori mengelola aset informasi

Pengelolaan aset informasi merupakan salah satu fondasi dalam keamanan teknologi informasi. Pengelolaan aset informasi memuat tentang informasi aset yang dimiliki, mekanisme penyimpanan aset, dan penentuan seberapa penting nilainya sehingga organisasi dapat melindungi aset informasi dengan efektif. Dengan demikian, melalui manajemen yang tepat, celah ancaman dan risiko terhadap aset dapat diminimalisir.

Kategori mengelola aset informasi terdiri atas subkategori mengelola daftar inventaris aset informasi; memetakan jalur komunikasi dan alur data pada organisasi; menyusun katalog sistem informasi eksternal yang menggunakan data milik organisasi; menyusun prioritas aset informasi berdasarkan klasifikasi, kekritisannya, dan nilai bisnisnya; serta mengendalikan aset informasi milik organisasi.

Adapun kekuatan yang dimiliki KPI pada kategori mengelola aset informasi antara lain :

- a. Organisasi mengelola daftar inventaris aset informasi baik secara manual maupun otomatisasi.
- b. Organisasi memetakan jalur komunikasi dan alur data pada organisasi.
- c. Organisasi mendokumentasikan dan mengelola daftar sistem informasi eksternal yang digunakan oleh KPI.
- d. Organisasi menyusun prioritas aset informasi berdasarkan klasifikasi, kekritisannya dan nilai bisnisnya.
- e. Organisasi mengendalikan aset informasi milik organisasi.

4. Kategori menilai dan mengelola risiko keamanan siber

Penilaian dan pengelolaan risiko keamanan siber perlu dilakukan secara berkala guna meminimalisir risiko ancaman. Dengan memahami tingkat risiko yang dihadapi, organisasi dapat merancang strategi pengamanan yang tepat dan efisien, serta menyusun prioritas terhadap risiko yang ada. Penilaian dan pengelolaan risiko keamanan siber bukan sekadar aktivitas teknis, melainkan bagian strategis dari tata kelola organisasi. Tanpa pemahaman risiko yang jelas, perlindungan keamanan menjadi tidak terarah dan potensi kerugian semakin besar.

Kategori menilai dan mengelola risiko keamanan siber terdiri atas mengidentifikasi dan mendokumentasikan kerentanan terhadap aset informasi; mengidentifikasi dan mendokumentasikan informasi terkait ancaman dan kerentanan yang diperoleh dari internal maupun eksternal; mengidentifikasi potensi dampak terhadap layanan Sistem Elektronik dan kemungkinan terjadinya dampak tersebut; menganalisis nilai risiko terhadap Sistem Elektronik; mengidentifikasi dan menyusun prioritas mitigasi terhadap risiko; menentukan dan mengomunikasikan toleransi risiko organisasi; mengelola hasil penerapan manajemen risiko yang telah ditetapkan; dan melakukan review terhadap hasil penerapan manajemen risiko.

Adapun kekuatan yang dimiliki KPI pada kategori menilai dan mengelola risiko keamanan siber antara lain :

- a. Organisasi mengidentifikasi dan mendokumentasikan kerentanan terhadap aset informasi.
- b. Organisasi mengidentifikasi dan mendokumentasikan informasi terkait ancaman dan kerentanan yang diperoleh dari internal maupun eksternal.
- c. Organisasi mengidentifikasi potensi dampak terhadap layanan sistem elektronik dan kemungkinan terjadinya dampak tersebut.
- d. Organisasi menganalisis nilai risiko terhadap sistem elektronik.

- e. Organisasi telah mengidentifikasi dan menyusun prioritas mitigasi terhadap risiko.
- f. Organisasi telah menentukan dan mengomunikasikan toleransi risiko organisasi.
- g. Organisasi mengelola hasil penerapan manajemen risiko yang telah ditetapkan.
- h. Organisasi melakukan revidi terhadap hasil penerapan manajemen risiko.

5. Kategori mengelola risiko rantai pasok

Pengelolaan risiko rantai pasok merupakan hal yang tidak luput dari perhatian dalam pengelolaan risiko TI. Hal ini dikarenakan adanya saling ketergantungan antara organisasi dengan penyedia rantai pasok yang dapat menjadi celah ancaman keamanan. Jika salah satu elemen dalam rantai pasok mengalami gangguan, baik karena serangan siber, bencana alam, kegagalan operasional, atau pelanggaran keamanan, maka layanan bisnis dapat terganggu. Akibatnya, kegagalan produksi, kerugian finansial bahkan aspek hukum dan reputasi juga mungkin akan terdampak.

Kategori mengelola risiko rantai pasok terdiri atas subkategori mengidentifikasi dan menetapkan proses manajemen risiko rantai pasok; mengidentifikasi pemasok dan mitra pihak ketiga dari setiap aset informasi di Sistem Elektronik; memastikan poin-poin perjanjian kerja sama yang digunakan untuk pemasok dan mitra pihak ketiga telah sesuai dengan kebijakan keamanan siber pada Penyelenggara Sistem Elektronik; melakukan pemeriksaan secara periodik terhadap pemasok dan mitra pihak ketiga terkait pemenuhan kewajiban kerja sama dan keamanannya; serta menyiapkan rencana penanggulangan dan pemulihan pada layanan Sistem Elektronik dengan pihak ketiga yang mendukung layanan tersebut.

Adapun kekuatan yang dimiliki KPI pada kategori mengelola risiko rantai pasok antara lain :

- a. Organisasi mengidentifikasi dan menetapkan proses manajemen risiko rantai pasok.
- b. Organisasi mengidentifikasi pemasok dan mitra pihak ketiga dari setiap aset informasi di sistem elektronik.
- c. Organisasi memastikan poin-poin perjanjian kerja sama yang digunakan untuk pemasok dan mitra pihak ketiga telah sesuai dengan kebijakan keamanan siber organisasi.
- d. Organisasi melakukan pemeriksaan secara periodik terhadap pemasok dan mitra pihak ketiga terkait pemenuhan kewajiban kerjasama dan keamanannya.
- e. Organisasi menyiapkan rencana penanggulangan dan pemulihan pada layanan sistem elektronik dengan pihak ketiga yang mendukung layanan tersebut.

B. Domain Proteksi

1. Kategori mengelola identitas, autentikasi, dan kendali akses

Pengelolaan identitas, autentikasi, dan kendali akses merupakan hal yang penting dalam menjaga keamanan sistem informasi dikarenakan berkaitan langsung dengan pengendalian siapa dan apa saja yang dapat diakses bagi setiap peran yang didefinisikan dalam organisasi. Dengan sistem identitas dan kontrol akses yang kuat, organisasi dapat mencegah akses tidak sah, membatasi dampak insiden keamanan, dan memastikan bahwa hanya pihak yang berwenang yang dapat mengakses data atau sistem sensitif, sehingga integritas, kerahasiaan, dan ketersediaan informasi tetap terjaga.

Kategori mengelola identitas, autentikasi, dan kendali akses terdiri atas beberapa subkategori yaitu mengelola identitas dan kredensial yang menggunakan layanan Sistem Elektronik; mengelola akses jarak jauh terhadap

layanan Sistem Elektronik; mengelola izin akses dan otorisasi layanan Sistem Elektronik; serta memastikan penerapan sistem autentikasi terhadap pengguna, perangkat, dan aset informasi sesuai tingkat risikonya.

Adapun kekuatan yang dimiliki KPI pada kategori mengelola identitas, autentikasi, dan kendali akses antara lain :

- a. Pengelolaan aset informasi dan personel yang menggunakan Sistem Elektronik telah diformalkan, diterapkan secara konsisten, dimonitor pelaksanaannya, direview secara berkala, serta dilakukan perbaikan berkelanjutan.
- b. Mekanisme identifikasi pengguna layanan, pemberian akses, dan otorisasi telah diformalkan, dilaksanakan di seluruh aspek, dengan pengawasan rutin, review berkala, serta dilakukan perbaikan berkelanjutan.
- c. Pencegahan serangan melalui perangkat atau jaringan telah memiliki prosedur formal yang diterapkan secara menyeluruh, dengan mekanisme monitoring, review periodik, serta dilakukan perbaikan berkelanjutan.
- d. Pemisahan hak akses, pembatasan komunikasi perangkat dan server serta sistem otentikasi untuk perangkat, pengguna, dan aset informasi telah diformalkan dan diterapkan secara menyeluruh.

2. Kategori melindungi aset fisik

Melindungi aset fisik adalah bagian penting dari keamanan informasi karena banyak risiko keamanan berasal dari akses langsung ke perangkat keras, server, jaringan, dan infrastruktur lainnya. Dengan melindungi aset fisik secara efektif, organisasi dapat mencegah gangguan operasional dan kebocoran data yang bisa terjadi akibat kerusakan langsung terhadap perangkat keras yang menyimpan atau memproses informasi penting.

Kategori melindungi aset fisik terdiri dari beberapa subkategori yaitu menyediakan prosedur operasional perlindungan terhadap aset fisik yang mendukung layanan Sistem Elektronik; memastikan proses perbaikan dan

pemeliharaan aset informasi pada layanan Sistem Elektronik dilakukan, dicatat, dan dikendalikan sesuai prosedur; memastikan proses pemeliharaan jarak jauh terhadap aset informasi pada layanan Sistem Elektronik dilakukan dengan persetujuan penanggung jawab layanan Sistem Elektronik dan didokumentasikan sesuai prosedur; memastikan lingkungan fisik aset informasi pada layanan Sistem Elektronik dipantau secara berkala untuk mendeteksi potensi ancaman; serta memastikan prosedur dan penerapannya senantiasa ditinjau dan ditingkatkan sesuai perkembangan ancaman.

Adapun kekuatan yang dimiliki KPI pada kategori melindungi aset fisik antara lain:

- a. Prosedur akses fisik, pelindungan aset, dan pengamanan perangkat komputer untuk pengolahan data Sistem Elektronik telah diformalkan secara lengkap, diterapkan pada secara menyeluruh, serta dilengkapi sarana pengamanan yang memadai.
- b. Prosedur pembaruan keamanan pada perangkat dan server telah diformalkan, dimonitor pelaksanaannya, direview secara berkala, serta menjadi subjek perbaikan berkelanjutan. Seluruh kegiatan pembaruan didokumentasikan secara utuh dan dilaporkan kepada manajemen secara formal dan periodik.
- c. Identifikasi dan pengelolaan perangkat dengan mekanisme pembaruan jarak jauh telah dilakukan secara formal dan menyeluruh, disertai pemeliharaan rutin yang terdokumentasi untuk seluruh perangkat yang disetujui.
- d. Pemantauan lingkungan fisik aset Sistem Elektronik serta mekanisme peninjauan, analisis, dan peningkatan kontrol keamanan berdasarkan hasil revidi telah diformalkan, diterapkan secara penuh, dimonitor, direview berkala, dan terus diperbaiki.

3. Kategori melindungi data

Proteksi data merupakan elemen vital dalam menjaga kerahasiaan, integritas, dan ketersediaan informasi penting. Organisasi perlu menerapkan berbagai langkah untuk memastikan bahwa data selalu terlindungi, baik selama penyimpanan maupun saat pengiriman.

Kategori melindungi data terdiri dari beberapa subkategori yaitu perlindungan terhadap data yang tersimpan pada Penyelenggara Sistem Elektronik; perlindungan terhadap data yang terkirim dari Penyelenggara Sistem Elektronik; memastikan ketersediaan kapasitas ruang penyimpanan data yang memadai; mengimplementasikan perlindungan dari kebocoran data; mengimplementasikan mekanisme pengecekan integritas data untuk verifikasi perangkat lunak, perangkat keras, dan data; memastikan prosedur pencadangan data dilakukan, dipelihara, dan diuji secara berkala; serta menyediakan kebijakan pemusnahan data.

Adapun kekuatan yang dimiliki KPI pada kategori melindungi data antara lain :

- a. Organisasi telah memiliki perjanjian keamanan yang disetujui secara formal oleh seluruh pihak eksternal, didukung kebijakan internal yang diformalkan, dimonitor, direview berkala, dan terus diperbaiki, serta format dokumen persetujuan yang disahkan pimpinan.
- b. Kebijakan dan prosedur enkripsi data serta saluran komunikasi (end-to-end antara perangkat dan server Sistem Elektronik) telah disahkan pimpinan dengan menggunakan kriptografi sesuai standar, diterapkan secara menyeluruh, dan pengamanan kunci enkripsi dikelola sepanjang siklus hidupnya.
- c. Strategi penyediaan sumber daya telah disahkan pimpinan dan diimplementasikan secara memadai. Pemeriksaan kualitas ruang penyimpanan data, deteksi kegagalan operasional, dan pembaruan perangkat lunak dilakukan secara berkala dan komprehensif.

- d. Seluruh proses pengadaan perangkat dan server telah mematuhi prosedur yang mensyaratkan penggunaan perangkat anti-tampering secara konsisten.
- e. Prosedur perlindungan jalur komunikasi, pemeriksaan integritas perangkat lunak, integritas informasi (transmisi, penerimaan, dan penyimpanan), serta verifikasi integritas perangkat keras telah disahkan dan diterapkan secara menyeluruh.
- f. Pengelolaan siklus hidup data, pemeliharaan, pembaruan, pencadangan sistem berkala dengan pengujian keandalan, serta penghapusan data permanen pada media yang akan dimusnahkan telah diatur dalam prosedur yang disahkan, dimonitor, direview berkala, dan terus diperbaiki. Keaslian sertifikat keamanan perangkat keras/lunak telah diverifikasi.

4. Kategori melindungi aplikasi

Perlindungan terhadap aplikasi sangat penting untuk memastikan bahwa layanan yang digunakan organisasi tetap aman dari berbagai ancaman. Kategori melindungi aplikasi terdiri dari beberapa subkategori yaitu menyediakan prosedur konfigurasi dasar sistem dan kendali perubahan konfigurasi; mengembangkan dan mengimplementasikan rencana manajemen kerentanan; memastikan bahwa lingkungan pengembangan dan pengujian sistem dibedakan dari lingkungan produksi atau operasional; serta Mengimplementasikan prosedur pengembangan sistem yang aman;

Adapun kekuatan yang dimiliki KPI pada kategori melindungi aplikasi antara lain:

- a. Organisasi telah memiliki prosedur pengendalian keamanan konfigurasi sistem dan perangkat yang diterapkan secara menyeluruh, meliputi:
 - Prosedur pengaturan keamanan kata sandi dan akses;
 - Prosedur pengelolaan perubahan konfigurasi perangkat;
 - Prosedur pembatasan pemasangan perangkat lunak pada *endpoint* dan server.

- b. Organisasi telah memiliki prosedur manajemen kerentanan yang komprehensif mencakup keseluruhan proses mulai dari pengumpulan informasi kerentanan, inventarisasi, prioritisasi, hingga perbaikan kerentanan pada aplikasi, serta diimplementasikan secara menyeluruh di organisasi.
- c. Organisasi telah memiliki prosedur segmentasi jaringan dan *environment* yang diterapkan secara menyeluruh antara lingkungan pengembangan, pengujian, dan produksi.
- d. Prosedur pengembangan perangkat lunak aman (secure software development) telah diterapkan secara konsisten di seluruh tahapan siklus hidup pengembangan perangkat lunak (SDLC), dengan dukungan dokumentasi, kebijakan, dan prosedur formal yang lengkap serta diterapkan secara organisasi luas.

5. Kategori melindungi jaringan

Proteksi jaringan memainkan peran penting dalam menjaga integritas dan keamanan sistem organisasi. Dengan melindungi koneksi dan mengatur traffic jaringan, risiko akses tidak sah dapat diminimalkan. Kategori melindungi jaringan terdiri dari beberapa subkategori yaitu menerapkan sistem yang dikonfigurasi dengan prinsip fungsionalitas minimum; menerapkan pelindungan terhadap jaringan komunikasi, akses sistem informasi, dan akses sistem kendali; menggunakan perangkat-perangkat jaringan yang menerapkan fungsi keamanan; memastikan integritas jaringan senantiasa dilindungi; menerapkan prosedur dan teknologi pencegahan malware; memastikan catatan audit atau log aktivitas ditentukan, didokumentasikan, diimplementasikan, dan ditinjau sesuai dengan kebijakan organisasi; serta memastikan bahwa informasi mengenai pelindungan terhadap teknologi dibagikan hanya kepada pihak terpercaya.

Adapun kekuatan yang dimiliki KPI pada kategori melindungi jaringan antara lain:

- a. Organisasi telah menerapkan pengendalian akses fisik dan logic, termasuk pemblokiran port jaringan, USB, dan yang tidak diperlukan pada *endpoint* dan server, dengan kebijakan yang sudah disahkan, termonitor, direview berkala, serta terus diperbaiki dan diotomatisasi.
- b. Organisasi telah memiliki prosedur terkait segmentasi dan zonasi jaringan yang direview secara berkala, dan terus dilakukan perbaikan berkelanjutan.
- c. Organisasi telah memiliki prosedur terkait pengujian integritas jaringan dan monitoring konfigurasi secara berkelanjutan, termasuk verifikasi efektivitas segmentasi jaringan.
- d. Organisasi telah memiliki kebijakan dan prosedur untuk pencegahan malware yang telah diterapkan secara menyeluruh, termonitor, dan direview berkala. Seperti:
 - Pencadangan data berkala,
 - Pemindaian removable media,
 - Pembaruan otomatis solusi anti-malware (antivirus, anti-spyware, spam filtering, web content filtering, IDS, IPS),
 - Patch management sistem operasi dan aplikasi
- e. Audit logging diterapkan secara komprehensif dengan ruang lingkup yang jelas, mekanisme review yang efektif untuk deteksi insiden berisiko tinggi, serta prosedur yang terformalisasi.
- f. Information sharing terkait efektivitas teknologi perlindungan data hanya dilakukan dengan mitra terpercaya melalui proses yang terformalisasi dan terkontrol.

6. Kategori melindungi sumber daya manusia

Sumber daya manusia organisasi merupakan garda terdepan dalam menjaga sistem dan data organisasi dari ancaman. Perlindungan SDM organisasi

mencakup aspek fisik, psikologis, dan digital. Dengan memastikan kesejahteraan dan keamanan personil keamanan TI, organisasi tidak hanya memperkuat pertahanannya, tetapi juga menjaga keberlanjutan operasional dan respons yang cepat terhadap ancaman.

Kategori melindungi SDM terdiri dari beberapa subkategori yaitu menerapkan prosedur pengelolaan keamanan terhadap personel; menyelenggarakan pelatihan dan peningkatan kesadaran keamanan siber; serta menyusun dan menerapkan kebijakan terkait kompetensi dan keahlian sumber daya manusia keamanan siber yang ada di Penyelenggara Sistem Elektronik.

Adapun kekuatan yang dimiliki KPI pada kategori melindungi SDM antara lain :

- a. Organisasi telah memiliki prosedur verifikasi latar belakang personel yang diterapkan secara konsisten terhadap seluruh calon personel, dengan mempertimbangkan aspek peraturan, etika, proporsionalitas bisnis, dan risiko keamanan. Dilakukan review secara berkala dan perbaikan berkelanjutan.
- b. Perjanjian Kerja dan Kerahasiaan (NDA), Perjanjian kontrak kerja secara eksplisit mengatur tanggung jawab personel dan organisasi terkait keamanan informasi. Perjanjian kerahasiaan telah diidentifikasi, didokumentasikan, ditinjau secara rutin, dan ditandatangani oleh seluruh personel serta pihak terkait. Proses review berkala dan perbaikan berkelanjutan telah berjalan efektif.
- c. Prosedur pendisiplinan telah diformalkan, dikomunikasikan dengan baik, dan diterapkan secara konsisten terhadap pelanggaran kebijakan keamanan informasi. Mekanisme review berkala dan perbaikan berkelanjutan tercatat dengan baik.
- d. Organisasi telah memiliki kebijakan terkait Pengendalian Pasca-Pemberhentian/Penggantian Jabatan yang dikomunikasikan kepada seluruh pegawai dan pihak ketiga setelah penghentian atau penggantian

tugas/jabatan, menunjukkan penerapan prinsip termination/offboarding yang memadai.

- e. Organisasi telah memiliki prosedur keamanan kerja jarak jauh yang diimplementasikan secara menyeluruh. Mekanisme pelaporan kejadian keamanan informasi melalui saluran resmi telah tersedia dan dikomunikasikan dengan baik kepada personel.
- f. Organisasi telah memiliki prosedur terkait program pelatihan dan pendidikan untuk seluruh karyawan, dengan beberapa proses sebagai berikut:
 - Identifikasi kebutuhan pelatihan yang terdokumentasi;
 - Mengklasifikasikan personel berdasarkan kriteria risiko dan kebutuhan;
 - Menyelenggarakan pelatihan secara menyeluruh kepada personel terkait;
 - Mengelola catatan pelatihan dan melakukan evaluasi pasca-pelatihan sebagai dasar perbaikan berkelanjutan;
 - Melakukan evaluasi berkala terhadap materi pelatihan dan menerapkan perbaikan secara konsisten.
- g. Organisasi telah memiliki kebijakan kompetensi SDM keamanan siber yang mengacu pada Peta Okupasi Keamanan Siber Nasional Indonesia, dengan proses sebagai berikut:
 - Mendokumentasikan, mengimplementasikan, mengevaluasi, dan memperbaiki secara berkelanjutan kebutuhan SDM keamanan siber;
 - Menetapkan program pengembangan kapasitas yang mencakup peningkatan kompetensi/sertifikasi, alih teknologi/keahlian, dan budaya kesadaran keamanan informasi;
 - Melaksanakan evaluasi berkala terhadap peningkatan kompetensi sesuai dokumen perencanaan.

C. Domain Deteksi

1. Kategori mengelola deteksi peristiwa siber

Mengelola deteksi peristiwa siber merupakan proses penting dalam sistem pertahanan keamanan informasi karena memungkinkan organisasi untuk secara cepat mengenali aktivitas mencurigakan atau ancaman yang sedang berlangsung. Dengan pengelolaan deteksi yang baik, organisasi dapat memperkecil risiko kerusakan, mempercepat respon terhadap insiden, dan meningkatkan kesiapsiagaan terhadap ancaman siber yang terus berkembang.

Kategori mengelola deteksi peristiwa siber terdiri dari beberapa subkategori yaitu menetapkan peran dan tanggung jawab organisasi pada kebijakan pendeteksian Peristiwa Siber; melaksanakan pendeteksian Peristiwa Siber sesuai persyaratan dan kebijakan yang berlaku; menguji prosedur pendeteksian Peristiwa Siber secara berkala; serta menyampaikan informasi hasil pendeteksian Peristiwa Siber kepada pihak yang berhak.

Adapun kekuatan yang dimiliki KPI pada kategori mengelola deteksi peristiwa siber antara lain:

- a. Organisasi telah menetapkan tata kelola peran dan tanggung jawab (termasuk yang melibatkan penyedia layanan) dalam rangka deteksi peristiwa keamanan yang telah mencapai tingkat kapabilitas matang (optimal). Hal ini dibuktikan dengan penerapan yang tidak hanya formal dan menyeluruh, tetapi juga mencakup aktivitas monitoring rutin, evaluasi efektivitas secara berkala, serta didukung upaya perbaikan berkelanjutan yang proaktif dan adaptif terhadap perubahan lingkungan maupun lanskap ancaman.
- b. Organisasi telah menerapkan dan memformalkan sistem untuk mendeteksi, menganalisis, dan merespons peristiwa keamanan di seluruh aspek organisasi.

- c. Proses pemantauan peristiwa keamanan siber telah dilaksanakan secara formal di seluruh aspek, serta telah selaras dengan peraturan, arahan, standar industri, dan aturan lain yang berlaku.
- d. Organisasi telah menerapkan proses pemantauan dan kontrol jaringan secara formal pada setiap titik masuk (entry point) ke jaringan organisasi.
- e. Organisasi telah memiliki dan menerapkan serangkaian Standar Operasional Prosedur (SOP) yang telah diformalkan di seluruh aspek, yang mencakup:
 - SOP Pengujian Perangkat Sistem Elektronik.
 - SOP Pendeteksian Peristiwa Keamanan Siber.
 - SOP Penyampaian Informasi hasil pendeteksian kejadian keamanan.
- f. Telah diterapkan dan diformalkan mekanisme pendukung proses deteksi di seluruh aspek, meliputi penggunaan Dokumen *Non-Disclosure Agreement* (NDA) dan pelaksanaan *review* prosedur secara berkala.

2. Kategori menganalisis anomali dan peristiwa siber

Menganalisis anomali dan peristiwa siber adalah proses mengamati dan menilai aktivitas yang tampak tidak biasa dalam sistem atau jaringan. Tujuannya adalah untuk mengetahui apakah aktivitas tersebut merupakan gangguan, kesalahan, atau tanda adanya ancaman keamanan. Dengan analisis ini, organisasi dapat mengambil langkah yang tepat untuk mencegah atau menangani masalah sebelum menjadi lebih serius.

Kategori menganalisis anomali dan peristiwa siber terdiri dari beberapa subkategori yaitu menetapkan dan mendokumentasikan ambang batas peringatan terhadap insiden operasional yang diharapkan organisasi terhadap jaringan komputer dan alur data; melaksanakan analisis terhadap Peristiwa Siber yang terdeteksi; menentukan dampak dari Peristiwa Siber yang terdeteksi; serta mendokumentasikan hasil analisis terhadap Peristiwa Siber yang terdeteksi.

Adapun kekuatan yang dimiliki KPI pada kategori menganalisis anomali dan peristiwa siber antara lain:

- a. Organisasi telah menerapkan proses dokumentasi hasil analisis peristiwa siber dan pelaporannya kepada pihak manajemen yang telah mencapai tingkat kapabilitas optimal. Proses ini telah diformalkan, diterapkan di seluruh aspek, serta dimonitor, dikaji ulang secara berkala, dan dilakukan perbaikan (atau otomatisasi jika teknis).
- b. Organisasi memiliki kerangka kerja Manajemen Risiko yang matang untuk mengidentifikasi dampak peristiwa keamanan. Ini dibuktikan dengan penerapan Dokumen Penilaian Risiko (Risk Assessment), IRP (Incident Response Program), DRP (Disaster Recovery Planning), dan BIA (Business Impact Analysis) yang telah diformalkan, dimonitor, dikaji ulang secara berkala, serta dilakukan perbaikan berkelanjutan di seluruh aspek.
- c. Organisasi telah memiliki fondasi yang terdefinisi dan formal (Indeks 3) untuk pelaksanaan teknis analisis dan investigasi insiden. Hal ini ditunjukkan dengan telah diterapkannya tools analisis, Petunjuk Teknis analisis, SOP Investigasi Insiden Keamanan Siber, serta format Laporan Analisis dan Laporan Investigasi secara menyeluruh di semua aspek organisasi.

3. Kategori memantau peristiwa siber berkelanjutan

Monitoring yang efektif adalah kunci untuk mendeteksi aktivitas mencurigakan atau anomali yang dapat mengancam keamanan sistem. Dengan pemantauan yang menyeluruh dan berkelanjutan, organisasi dapat segera merespon insiden sebelum terjadi dampak yang lebih besar.

Kategori memantau peristiwa siber berkelanjutan terdiri dari beberapa subkategori yaitu menerapkan prosedur pendeteksi kode berbahaya dan tak berizin; memonitor kegiatan personel yang berada di dalam lingkup Sistem Elektronik; memonitor kegiatan pihak ketiga yang berada di dalam lingkup

Sistem Elektronik; serta menerapkan teknologi pemindaian kerentanan terhadap Sistem Elektronik.

Adapun kekuatan yang dimiliki KPI pada kategori memantau peristiwa siber berkelanjutan antara lain:

- a. Organisasi telah menerapkan kapabilitas deteksi ancaman siber yang matang. Hal ini dibuktikan dengan penerapan teknologi pendeteksi perilaku abnormal pada sistem dan jaringan, serta prosedur formal untuk memvalidasi informasi/file (terkait kode berbahaya, integritas, dan keaslian) dari dunia maya. Seluruh proses dan teknologi ini telah diterapkan di semua aspek, diformalkan, dimonitor, dikaji ulang secara berkala, serta didukung upaya perbaikan berkelanjutan dan pembaruan, termasuk yang mengarah pada otomatisasi.
- b. Telah diterapkan prosedur pengawasan yang matang untuk memonitor aktivitas personel internal dan pihak ketiga di dalam lingkup Sistem Elektronik. Prosedur ini (untuk memastikan tidak ada koneksi, instalasi perangkat keras, atau perangkat lunak tak berizin) telah diformalkan, dimonitor, dikaji ulang berkala, dan diperbaiki secara berkelanjutan di seluruh aspek.
- c. Organisasi telah menerapkan program manajemen kerentanan yang matang. Telah dipastikan bahwa seluruh perangkat teknologi telah diuji keamanannya (melalui *vulnerability assessment*, *penetration testing*, atau audit keamanan). Proses ini telah diformalkan, dimonitor, dikaji ulang berkala, didukung perbaikan prosedur, dan mengarah pada otomatisasi.
- d. Organisasi telah menerapkan dan memformalkan prosedur untuk memastikan adanya pemeriksaan rutin pada perangkat dan server yang dikelola di seluruh aspek organisasi.

D. Domain Penanggulangan dan Pemulihan

1. Kategori menyusun perencanaan penanggulangan dan pemulihan insiden siber

Menyusun perencanaan penanggulangan dan pemulihan insiden siber adalah langkah penting untuk memastikan organisasi siap merespons saat terjadi serangan. Kategori menyusun perencanaan penanggulangan dan pemulihan insiden siber terdiri dari beberapa subkategori yaitu menyusun dan menetapkan rencana tanggap Insiden Siber yang disetujui oleh pimpinan organisasi; menyusun dan menetapkan rencana keberlangsungan kegiatan yang disetujui oleh pimpinan organisasi; memastikan rencana tanggap Insiden Siber dan rencana keberlangsungan kegiatan dilaksanakan dan disimulasikan secara berkala; memastikan personel yang mengelola sistem elektronik mengetahui peran dan prosedur penanggulangan dan pemulihan sesuai rencana tanggap Insiden Siber dan rencana keberlangsungan kegiatan; memastikan personel yang mengelola sistem elektronik memahami prosedur penggunaan rekam cadang.

Adapun kekuatan yang dimiliki KPI pada kategori menyusun perencanaan penanggulangan dan pemulihan insiden siber antara lain :

- a. Organisasi telah menyusun dan menetapkan Rencana Tanggap Insiden Siber (IR Plan) yang sangat matang dan komprehensif. Rencana ini telah diformalkan, mencakup pembagian peran yang jelas (manajemen, personel, pihak lain), seluruh tahapan (persiapan, identifikasi, kontainmen, eradiksi, pemulihan, peningkatan), dan dilengkapi skenario insiden. Proses ini didukung oleh kebijakan komunikasi tertulis, serta dilakukan *review* dan perbaikan secara berkala.
- b. Organisasi memiliki kerangka kerja Keberlangsungan Kegiatan (*Business Continuity*) yang matang. Hal ini dibuktikan dengan adanya kebijakan formal (yang di-*review* dan diperbaiki berkala) untuk penetapan daftar fungsi/layanan kritis dan pembagian peran; strategi, tahapan, dan target

waktu pemulihan; serta penetapan daftar sumber daya, peralatan, dan personel yang dibutuhkan untuk pemulihan.

- c. Organisasi telah memastikan kesiapan personel dengan kapabilitas yang matang. Hal ini mencakup penetapan Tim Tanggap Insiden Siber (TTIS) yang formal, di-review, dan diperbaiki berkala. Seluruh personel dipastikan mengetahui peran dan urutan pengoperasian dalam penanggulangan/pemulihan serta dapat mempraktikkannya.
- d. Terdapat prosedur rekam cadang (*backup*) yang telah ditetapkan dan dilaksanakan sesuai dengan rencana. Prosedur ini memiliki penanggung jawab yang spesifik dan memastikan media yang digunakan untuk menyimpan data telah diamankan.
- e. Organisasi telah membangun fondasi yang formal untuk proses pendukung respons. Hal ini mencakup:
 - Pelaksanaan simulasi Rencana Tanggap Insiden Siber dan Keberlangsungan Kegiatan secara berkala.
 - Penetapan mekanisme eskalasi formal untuk melibatkan pihak eksternal (seperti TTIS sektoral/nasional, aparat penegak hukum), termasuk ketersediaan kontak narahubung.
 - Keberadaan aturan (draf/final) terkait komunikasi rencana keberlangsungan dan distribusi informasi pasca-insiden kepada pihak berwenang.

2. Kategori menganalisis dan melaporkan insiden siber

Menganalisis dan melaporkan insiden siber merupakan proses penting untuk memahami penyebab, dampak, dan cara penanganan insiden yang terjadi. Kategori menganalisis dan melaporkan insiden siber terdiri dari beberapa subkategori yaitu mengumpulkan informasi kondisi sistem elektronik terkini baik dari hasil deteksi internal maupun sumber informasi eksternal; mengidentifikasi dan menganalisis potensi dampak dari Insiden Siber;

memastikan Insiden Siber dikategorikan sesuai kriteria yang telah ditetapkan; serta memastikan bahwa Insiden Siber dilaporkan kepada pihak yang terkait.

Adapun kekuatan yang dimiliki KPI pada kategori menganalisis dan melaporkan insiden siber antara lain:

- a. Organisasi telah menerapkan proses identifikasi dan analisis potensi dampak Insiden Siber (pada layanan sistem elektronik, organisasi, dan pihak terkait) yang telah matang. Hal ini dibuktikan dengan adanya prosedur pelaksanaan yang formal, pelaksanaan monitoring berkala, serta adanya kaji ulang prosedur dan upaya perbaikan berkelanjutan terhadap proses tersebut.
- b. Organisasi telah menerapkan dan memformalkan prosedur untuk penanganan laporan insiden, yang mencakup:
 - Proses pengumpulan, kategorisasi, dan prioritas laporan Insiden Siber sesuai dampak risiko.
 - Pelaporan informasi Insiden Siber kepada pihak yang berwenang sesuai dengan kriteria yang ditetapkan organisasi dan peraturan perundangan yang berlaku.
 - Pelaksanaan proses koordinasi dengan para pemangku kepentingan sesuai dengan Rencana Tanggap Insiden Siber.

3. Kategori melaksanakan penanggulangan dan pemulihan insiden siber

Penanggulangan yang baik memerlukan sumber daya yang memadai untuk menganalisis dan merespon insiden secara efektif. Sedangkan Pemulihan insiden yang terstruktur dan terdokumentasi memastikan bahwa organisasi bisa dengan cepat kembali normal setelah insiden terjadi. Langkah-langkah pemulihan yang jelas membantu mengurangi dampak dan mencegah masalah lebih lanjut.

Kategori melaksanakan penanggulangan dan pemulihan insiden siber terdiri dari beberapa subkategori yaitu memastikan Insiden Siber diisolasi dan dimitigasi sesuai rencana tanggap Insiden Siber; mengumpulkan dan

memelihara bukti Insiden Siber dari sistem elektronik terdampak; menginvestigasi dan eradikasi penyebab Insiden Siber; mengoordinasikan dengan pihak terkait dalam rangka eskalasi penanggulangan Insiden Siber; memastikan setiap aset informasi diperiksa keamanannya setelah penanganan Insiden Siber; melaksanakan prosedur pencadangan dan pemulihan sistem dan data sesuai rencana keberlangsungan kegiatan; menentukan dan menerapkan retensi terhadap hasil pencadangan yang sudah tidak terpakai sesuai ketentuan; pengujian ulang terhadap fungsi sistem elektronik dan fungsi pendukung untuk memastikan capaian pemulihan terpenuhi; memastikan organisasi memiliki dan mengelola strategi komunikasi publik ketika terjadi Insiden Siber dan setelah penanggulangan serta pemulihan Insiden Siber; serta menyampaikan informasi penanggulangan dan pemulihan Insiden Siber kepada pihak terkait.

Adapun kekuatan yang dimiliki KPI pada kategori melaksanakan penanggulangan dan pemulihan insiden siber antara lain:

- a. Organisasi memiliki kapabilitas pencadangan (backup) dan pemulihan (recovery) yang sangat matang. Hal ini dibuktikan dengan:
 - Pelaksanaan prosedur pemulihan sistem/data dalam keadaan darurat.
 - Pelaksanaan simulasi periodik terhadap prosedur pemulihan.
 - Penerapan rekam cadang (backup) secara otomatis (memanfaatkan *job-scheduling*).
 - Pendokumentasian hasil pelaksanaan rekam cadang. Seluruh proses ini telah diterapkan menyeluruh, dimonitor, dikaji ulang, serta terintegrasi dengan proses bisnis atau sistem terotomatisasi.
- b. Organisasi telah menerapkan proses pasca-insiden, komunikasi, dan pelaporan yang matang. Ini mencakup:
 - Prosedur untuk memastikan seluruh fungsi layanan sistem elektronik beroperasi normal pasca-insiden.

- Prosedur untuk memastikan komunikasi proses penanganan dan pemulihan insiden kepada pihak yang berkepentingan (sesuai peraturan).
 - Prosedur untuk kategorisasi dan penyimpanan informasi/bukti insiden (berdasarkan dampak, penyebab, dll.). Seluruh proses ini telah dimonitor, dikaji ulang secara berkelanjutan, dan terintegrasi dengan proses bisnis atau sistem terotomatisasi.
- c. Organisasi telah menyusun laporan hasil penanganan Insiden Siber secara komprehensif (mencakup jenis indikasi, dampak, rekomendasi, dll.), yang telah disahkan oleh pimpinan, dan telah disampaikan kepada Kementerian atau Lembaga di sektor terkait.
- d. Telah diterapkan prosedur penanganan terhadap perangkat yang terpengaruh oleh Insiden Siber dan prosedur pendokumentasian hasil mitigasi. Kedua prosedur ini telah dijalankan secara menyeluruh, dimonitor, dan dikaji ulang secara berkelanjutan.
- e. Organisasi telah memiliki fondasi proses yang telah diformalkan dan diterapkan secara menyeluruh di semua area penanggulangan insiden lainnya. Ini mencakup prosedur untuk *containment* (isolasi), penentuan prioritas respons, forensik digital, eradikasi kode berbahaya, eskalasi ke TTIS sektoral/nasional, pemeriksaan aset pasca-insiden, enkripsi data rekam cadang, penentuan jadwal rekam cadang, serta prosedur penyimpanan dan pemusnahan media rekam cadang.

4. Kategori meningkatkan keamanan setelah terjadinya insiden siber

Peningkatan keamanan setelah terjadinya insiden siber adalah langkah penting untuk mencegah kejadian serupa di masa mendatang dan memperkuat pertahanan sistem. Kategori meningkatkan keamanan setelah terjadinya insiden siber terdiri atas beberapa subkategori yaitu meninjau kembali efektivitas Kontrol Keamanan yang telah diterapkan; mereviu dan/atau

memperbarui dokumen rencana tanggap Insiden Siber dan rencana keberlangsungan kegiatan secara berkala; mengumpulkan dan memelihara hasil forensik digital; serta meninjau efektivitas kinerja penanganan insiden yang dilakukan oleh tim tanggap Insiden Siber secara berkala.

Adapun kekuatan yang KPI pada kategori meningkatkan keamanan setelah terjadinya insiden siber antara lain:

- a. Organisasi telah memiliki proses evaluasi kontrol keamanan yang sangat matang. Proses ini mencakup evaluasi relevansi kontrol terhadap spektrum ancaman (didasarkan pada kebijakan), perbandingan dengan standar nasional/internasional, dan pelaksanaan perbaikan/penambahan kontrol secara berkala, di mana hasilnya disusun dalam laporan evaluasi formal.
- b. Terdapat proses manajemen risiko yang matang dan dinamis. Organisasi secara berkala mendokumentasikan kerentanan, ancaman, atau risiko yang baru ditemukan beserta rencana mitigasinya ke dalam dokumen pengelolaan risiko. Dokumen ini beserta pembaruannya telah disahkan oleh pimpinan organisasi.
- c. Organisasi telah memformalkan proses reviu dan pembaruan terhadap dokumen Rencana Tanggap Insiden Siber, yang telah disahkan oleh pimpinan.
- d. Telah diterapkan prosedur formal untuk pelaksanaan forensik digital sesuai dengan praktik terbaik. Proses ini mencakup penyusunan laporan hasil forensik, pemeliharaan informasi relevan, dan pelaporan internal hasil temuan (yang ditandatangani Tim Forensik) kepada Pimpinan Organisasi atau Ketua TTIS.
- e. Organisasi telah menerapkan proses peninjauan (termasuk evaluasi mandiri) terhadap efektivitas kinerja penanganan insiden yang dilakukan oleh Tim Tanggap Insiden Siber (TTIS), serta telah menindaklanjutinya dengan langkah-langkah perbaikan yang diperlukan (meliputi segi teknologi, tata kelola, atau peningkatan kapasitas SDM).

V. Kelemahan/ Kekurangan

Berdasarkan hasil verifikasi penilaian kematangan keamanan siber, dapat disimpulkan kondisi kelemahan/kekurangan keamanan siber pada KPI sebagai berikut:

A. Domain Identifikasi

1. Kategori mengidentifikasi peran dan tanggung jawab organisasi

Kegagalan dalam mengidentifikasi peran dan tanggung jawab dalam organisasi berdampak serius terhadap efektivitas pengelolaan keamanan dan respons terhadap insiden siber. Berdasarkan hasil wawancara verifikasi, pada kategori ini belum ditemukan kelemahan yang signifikan.

2. Kategori menyusun strategi, kebijakan, dan prosedur

Kegagalan dalam menyusun strategi, kebijakan, dan prosedur berdampak pada lemahnya arah, pengendalian, dan konsistensi dalam pengelolaan keamanan informasi. Berdasarkan hasil wawancara verifikasi, pada kategori ini belum ditemukan kelemahan yang signifikan.

3. Kategori mengelola aset informasi

Manajemen aset yang efektif sangat penting untuk memastikan ketersediaan dan keamanan sumber daya organisasi. Kelemahan dalam pengelolaan aset dapat menyebabkan risiko terhadap keamanan informasi dan operasional. Berdasarkan hasil wawancara verifikasi, pada kategori ini belum ditemukan kelemahan yang signifikan.

4. Kategori menilai dan mengelola risiko keamanan siber

Manajemen risiko yang baik memungkinkan organisasi untuk mengidentifikasi dan mengelola ancaman secara efektif. Kelemahan dalam pengelolaan risiko dapat meningkatkan kerentanan terhadap serangan dan

gangguan operasional. Berdasarkan hasil wawancara verifikasi, pada kategori ini belum ditemukan kelemahan yang signifikan.

5. Kategori mengelola risiko rantai pasok

Kegagalan pada pengelolaan rantai pasok mengakibatkan terganggunya kelancaran operasional, meningkatnya risiko keamanan, serta potensi kerugian finansial dan reputasi bagi organisasi. Ketergantungan pada pihak ketiga tanpa pengawasan yang memadai dapat membuka celah bagi ancaman seperti kebocoran data, serangan siber, atau keterlambatan pengiriman layanan dan barang. Berdasarkan hasil wawancara verifikasi, pada kategori ini belum ditemukan kelemahan yang signifikan.

B. Domain Proteksi

1. Kategori mengelola identitas, autentikasi, dan kendali akses

Manajemen identitas dan akses yang kuat sangat penting untuk melindungi sistem dan data sensitif dari akses tidak sah. Kelemahan dalam pengelolaan akses dapat menyebabkan risiko tinggi terkait penyalahgunaan identitas dan pelanggaran keamanan. Berdasarkan hasil wawancara verifikasi, pada kategori ini belum ditemukan kelemahan yang signifikan.

2. Kategori melindungi aset fisik

Kegagalan dalam melindungi aset fisik berdampak pada meningkatnya risiko akses tidak sah, pencurian perangkat, sabotase, serta kerusakan sistem yang dapat mengganggu operasional organisasi. Oleh karena itu, perlindungan fisik yang lemah dapat menjadi titik lemah serius dalam sistem keamanan informasi organisasi. Berdasarkan hasil wawancara verifikasi, pada kategori ini belum ditemukan kelemahan yang signifikan.

3. Kategori melindungi data

Proteksi data yang baik mencakup perlindungan atas integritas dan kerahasiaan data, baik saat data disimpan maupun diproses. Kelemahan dalam pengelolaan data dapat meningkatkan risiko hilangnya integritas data atau kebocoran informasi sensitif. Berdasarkan hasil wawancara verifikasi, pada kategori ini belum ditemukan kelemahan yang signifikan.

4. Kategori melindungi aplikasi

Proteksi aplikasi sangat penting untuk menjaga keamanan perangkat lunak yang digunakan organisasi dari ancaman eksternal dan internal. Kelemahan dalam manajemen keamanan aplikasi dapat membuat sistem lebih rentan terhadap serangan dan eksploitasi. Berdasarkan hasil wawancara verifikasi, pada kategori ini belum ditemukan kelemahan yang signifikan.

5. Kategori melindungi jaringan

Proteksi jaringan yang kuat adalah elemen penting dalam menjaga keamanan informasi dan mencegah akses tidak sah. Kelemahan dalam pengelolaan jaringan dapat meningkatkan risiko serangan siber dan penyebaran ancaman di seluruh jaringan organisasi. Berdasarkan hasil wawancara verifikasi, pada kategori ini belum ditemukan kelemahan yang signifikan.

6. Kategori melindungi sumber daya manusia

Kegagalan dalam proteksi SDM mengakibatkan meningkatnya risiko kesalahan manusia, kebocoran informasi, dan potensi ancaman dari dalam (insider threat) yang dapat membahayakan keamanan organisasi. Oleh karena itu, pengelolaan dan perlindungan SDM merupakan elemen krusial dalam sistem pertahanan siber yang menyeluruh. Berdasarkan hasil wawancara verifikasi, pada kategori ini belum ditemukan kelemahan yang signifikan.

C. Domain Deteksi

1. Kategori mengelola deteksi peristiwa siber

Kemampuan mendeteksi peristiwa siber secara cepat dan akurat sangat penting dalam menjaga keamanan dan ketahanan sistem informasi. Kegagalan mendeteksi peristiwa siber mengakibatkan ancaman atau serangan tidak teridentifikasi sejak dini, sehingga dapat berkembang tanpa terpantau dan menimbulkan kerusakan yang lebih besar. Berdasarkan hasil wawancara verifikasi, tidak teridentifikasi adanya kelemahan signifikan pada kategori ini.

2. Kategori menganalisis anomali dan peristiwa siber

Kegagalan dalam menganalisis anomali dan peristiwa siber berdampak pada ketidakmampuan organisasi untuk membedakan antara aktivitas normal dan ancaman yang sebenarnya, sehingga potensi serangan bisa luput dari perhatian. Berdasarkan hasil wawancara verifikasi, untuk kategori ini tidak teridentifikasi adanya kelemahan yang signifikan.

3. Kategori memantau peristiwa siber berkelanjutan

Kegagalan dalam pemantauan peristiwa siber secara berkelanjutan berakibat pada terlewatnya tanda-tanda awal serangan, yang memungkinkan ancaman berkembang tanpa terdeteksi dalam jangka waktu lama. Berdasarkan hasil wawancara verifikasi, untuk kategori ini tidak teridentifikasi adanya kelemahan yang signifikan.

D. Domain Penanggulangan dan Pemulihan

1. Kategori menyusun perencanaan penanggulangan dan pemulihan insiden siber

Penyusunan rencana penanggulangan dan pemulihan insiden siber adalah langkah penting untuk memastikan organisasi siap merespons saat terjadi serangan. Jika penyusunan rencana penanggulangan dan pemulihan insiden

siber tidak dilakukan, maka organisasi akan kesulitan merespons secara cepat dan terkoordinasi saat terjadi serangan.

Berdasarkan hasil wawancara verifikasi, pada kategori ini teridentifikasi satu kelemahan implementasi minor, yaitu aturan mengenai penerbitan dan distribusi informasi pasca-insiden keamanan belum tersosialisasi atau dipraktikkan secara menyeluruh, di mana baru "sebagian personel sudah mengetahuinya dan sebagian sudah mempraktikkannya".

2. Kategori menganalisis dan melaporkan insiden siber

Kegagalan menganalisis dan melaporkan insiden siber mengakibatkan ketidakpahaman terhadap penyebab, dampak, dan jalur serangan yang terjadi, sehingga organisasi sulit mengambil tindakan perbaikan yang tepat. Beberapa kelemahan yang ditemukan pada kategori ini antara lain:

- a. Organisasi tidak memeriksa hasil analisis deteksi peristiwa siber untuk menilai ada atau tidaknya anomali pada sistem. Hal ini mengindikasikan adanya kesenjangan fundamental dalam siklus analisis insiden internal.
- b. Organisasi tidak memiliki layanan aduan/pelaporan (seperti *helpdesk* atau kontak khusus insiden) yang memungkinkan pengguna layanan atau sumber eksternal (seperti mitra atau Tim Tanggap Insiden Siber nasional) untuk melaporkan peristiwa siber.

3. Kategori melaksanakan penanggulangan dan pemulihan insiden siber

Penanggulangan insiden siber membutuhkan kemampuan investigasi, pelaporan, dan pemulihan yang cepat dan efektif. Kelemahan dalam aspek ini dapat memperlambat proses pemulihan, sehingga meningkatkan dampak dari insiden. Sedangkan Pemulihan setelah insiden sangat penting untuk mengembalikan operasional bisnis ke kondisi normal secepat mungkin. Kelemahan dalam proses pemulihan dapat memperpanjang *downtime*, yang

menyebabkan kerugian lebih besar dan gangguan operasional yang berkepanjangan.

Kelemahan yang ditemukan pada kategori ini yaitu proses penyusunan dan penerapan strategi komunikasi publik teridentifikasi belum diimplementasikan secara menyeluruh (baru sebagian besar) dan belum diformalkan. Ini merupakan kesenjangan dalam kesiapan organisasi mengelola informasi yang perlu disampaikan terkait Insiden Siber.

4. Kategori Meningkatkan Keamanan setelah terjadinya insiden siber

Kegagalan dalam meningkatkan keamanan setelah terjadinya insiden siber dapat berdampak serius terhadap keberlangsungan dan ketahanan sistem elektronik suatu organisasi. Tanpa adanya evaluasi menyeluruh dan tindak lanjut berupa perbaikan atau penguatan sistem keamanan, kerentanan yang sama dapat dimanfaatkan kembali oleh pihak tidak bertanggung jawab untuk melancarkan serangan serupa di masa mendatang. Hal ini tidak hanya meningkatkan risiko terulangnya insiden, tetapi juga dapat menyebabkan kerusakan yang lebih besar, kehilangan data yang lebih luas, gangguan operasional yang berkepanjangan, serta menurunnya tingkat kepercayaan pemangku kepentingan, termasuk mitra, regulator, dan masyarakat. Karena itu, peningkatan keamanan pasca-insiden merupakan langkah krusial yang harus dilakukan secara sistematis dan berkelanjutan guna memastikan sistem informasi tetap terlindungi dan siap menghadapi potensi ancaman siber di masa depan. Berdasarkan hasil wawancara verifikasi, tidak teridentifikasi adanya kelemahan (weakness) yang signifikan pada Kategori ini.

VI. Rekomendasi

Berdasarkan hasil verifikasi penilaian kematangan keamanan siber, berikut ini rekomendasi yang dapat dilakukan dalam rangka peningkatan kematangan siber pada

Kilang Pertamina Internasional (KPI). Rekomendasi disusun dalam tiga aspek utama yaitu *People*, *Process*, dan *Technology*. Setiap aspek memiliki peran penting dalam menciptakan lingkungan yang aman dan terstruktur dalam organisasi. Rekomendasi ini difokuskan pada peningkatan keterampilan dan tanggung jawab di antara personil (*People*), pengembangan dan penerapan kebijakan serta prosedur yang efektif (*Process*), dan penerapan teknologi canggih untuk mendukung upaya keamanan siber (*Technology*).

A. *People*

Dalam konteks kematangan keamanan siber, keterlibatan dan pemberdayaan sumber daya manusia dalam organisasi merupakan pondasi yang tak tergantikan. Rekomendasi berikut mencakup langkah penting yang berfokus pada peningkatan pengetahuan, pelatihan, serta pembentukan tim untuk memperkuat keamanan informasi. Peningkatan yang diperlukan untuk memperkuat aspek *people* antara lain :

1. Senantiasa membangun budaya dan kesadaran keamanan informasi yang berkelanjutan melalui pelatihan kesadaran keamanan informasi, kampanye keamanan internal, simulasi insiden, simulasi phishing dan social engineering, dan pelaporan insiden keamanan melalui kanal resmi, baik kepada karyawan internal maupun kepada pihak ketiga.
2. Organisasi dapat menugaskan personel (atau tim) yang memiliki kompetensi memadai untuk bertanggung jawab melakukan analisis manual terhadap hasil deteksi peristiwa siber guna mengidentifikasi anomali.
3. Meningkatkan kapabilitas penanganan insiden tingkat lanjut dengan peningkatan kemampuan personel dalam forensik digital untuk melakukan investigasi dan analisis insiden siber dengan lebih mendalam.
4. Organisasi dapat melakukan sosialisasi dan pelatihan menyeluruh kepada personel terkait (misalnya tim PR, Manajemen, Legal) setelah strategi komunikasi publik diformalkan, untuk memastikan implementasi yang konsisten di seluruh aspek.

5. Organisasi dapat melakukan sosialisasi kepada pimpinan, Tim Tanggap Insiden Siber (TTIS), dan tim Legal mengenai prosedur formal, batasan, dan pertimbangan (termasuk klasifikasi informasi) dalam penyampaian laporan hasil forensik digital kepada aparat penegak hukum.
6. Organisasi dapat memastikan sosialisasi prosedur internal secara menyeluruh, terutama terkait aturan penerbitan dan distribusi informasi pasca-insiden (untuk memastikan dipahami oleh semua personel, tidak hanya sebagian) serta prosedur komunikasi Rencana Keberlangsungan Kegiatan kepada pihak-pihak terkait.

B. Process

Bagian yang tak terpisahkan dari kesiapan keamanan siber adalah pengaturan proses yang ketat dan terstruktur. Rekomendasi di bawah ini menyoroti langkah-langkah kunci dalam pengaturan kebijakan, prosedur, manajemen risiko, serta evaluasi guna membangun landasan yang kokoh bagi keamanan informasi organisasi. Peningkatan yang diperlukan untuk memperkuat aspek process antara lain :

1. Organisasi dapat melakukan reviu dan pembaruan kebijakan serta prosedur keamanan informasi secara berkala agar tetap relevan dengan perubahan organisasi, hasil evaluasi penerapan sebelumnya, serta standar keamanan terbaru.
2. Organisasi dapat membangun mekanisme evaluasi dan pembelajaran berkelanjutan untuk memastikan bahwa proses keamanan siber selalu diperbaiki dan disesuaikan dengan ancaman maupun permasalahan yang muncul selama implementasi.
3. Organisasi dapat menyusun prosedur operasional standar (SOP) yang formal terkait tata cara pemeriksaan hasil analisis deteksi peristiwa siber, yang akan menjadi panduan bagi personel yang ditugaskan.
4. Organisasi dapat membangun prosedur formal yang mencakup alur penerimaan, pencatatan, analisis awal, dan eskalasi laporan/aduan insiden siber yang diterima dari pengguna internal maupun pihak eksternal.

5. Organisasi dapat memformalkan (menyusun dokumen SOP/Kebijakan) strategi komunikasi publik dan memastikan strategi tersebut diterapkan secara menyeluruh di semua lini organisasi.
6. Laporan monitoring yang dilakukan oleh pihak ketiga sebaiknya dibuatkan laporan bulanan dan tahunan, untuk melihat *threat lanscape* organisasi agar bisaantisipasi kemungkinan serangan yang akan datang.
7. Organisasi dapat mengimplementasikan siklus monitoring dan kaji ulang (review) berkala untuk mengukur efektivitas seluruh prosedur teknis yang telah diformalkan, termasuk namun tidak terbatas pada: prosedur *containment*, forensik, eradikasi, pelaksanaan simulasi (IRP/BCP), mekanisme eskalasi, dan seluruh prosedur terkait keamanan rekam cadang (enkripsi, jadwal, retensi, pemusnahan).
8. Organisasi dapat menetapkan dan memformalkan frekuensi (jadwal) pelaksanaan untuk proses kaji ulang yang masih bersifat *ad-hoc* (jika diperlukan), terutama untuk:
 - Reviu dan pembaruan dokumen Rencana Tanggap Insiden Siber.
 - Peninjauan efektivitas kinerja Tim Tanggap Insiden Siber (TTIS) (misalnya: minimal satu kali dalam satu tahun).
9. Organisasi dapat memformalkan prosedur krusial lainnya yang teridentifikasi, seperti prosedur eskalasi dan pelaporan hasil forensik ke aparat penegak hukum serta kebijakan komunikasi Rencana Keberlangsungan Kegiatan.

C. Technology

Teknologi yang tepat merupakan pilar penting dalam perkuatan keamanan siber suatu organisasi. Berfokus pada infrastruktur yang aman dan alat-alat yang canggih, rekomendasi berikut ini menguraikan langkah-langkah untuk mengadopsi teknologi terkini guna memperkuat pertahanan terhadap ancaman siber :

1. Organisasi dapat mengimplementasikan platform atau sarana teknologi (misalnya *helpdesk/ticketing system*, alamat email khusus, atau *hotline*) sebagai kanal resmi untuk menerima dan mengelola aduan/laporan insiden siber.
2. Organisasi dapat memastikan implementasi teknis dan konsisten terhadap teknologi enkripsi untuk mengamankan data yang disimpan pada media penyimpanan rekam cadang (*backup*) sesuai dengan prosedur yang telah ditetapkan.
3. Sebagai langkah optimalisasi (setelah proses manual terbentuk), organisasi dapat mengkaji implementasi sistem terotomatisasi untuk menganalisis peristiwa siber (seperti SIEM/SOAR), serta mengkaji otomatisasi pada proses lain seperti pemeriksaan rutin server dan pemantauan peristiwa siber untuk meningkatkan efisiensi dan akurasi deteksi.

VII. Tindak Lanjut

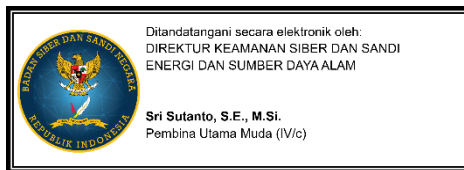
Beberapa hal yang dapat dilaksanakan sebagai tindak lanjut adalah sebagai berikut:

1. Kolaborasi dan Sinergi BSSN dengan Kilang Pertamina Internasional (KPI) dalam peningkatan Kapabilitas SDM melalui pelaksanaan Bimtek/ *Workshop*/ Pelatihan/ Sosialisasi Keamanan Siber di Internal KPI.
2. Pembahasan Kerjasama antara BSSN dan Kilang Pertamina Internasional (KPI) dalam penerapan keamanan siber khususnya terkait dengan lingkup:
 - a. Asistensi dan Konsultasi Penyiapan Kebijakan Keamanan Siber;
 - b. Asistensi dan Konsultasi Pengujian Keamanan;
 - c. Asistensi dan konsultasi Penerapan Perlindungan Data/Informasi;
 - d. Asistensi dan Konsultasi Penanganan Insiden.

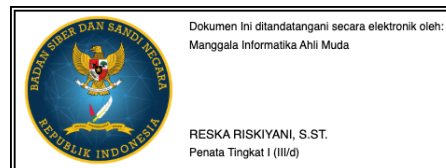
PENUTUP

Demikian disampaikan laporan kegiatan penilaian kematangan keamanan siber pada Kilang Pertamina Internasional (KPI), sebagai bahan masukan bagi pimpinan dalam menentukan kebijakan lebih lanjut.

Mengetahui,
Direktur Kamsisan ESDA,



Depok, 10 November 2025
Tim Verifikasi BSSN,



INFORMASI KONTAK

Informasi lebih lanjut mengenai Kegiatan Pengukuran Kematangan Keamanan Siber dapat menghubungi:

Direktorat Keamanan Siber dan Sandi Energi dan Sumber Daya Alam
Deputi Bidang Keamanan Siber dan Sandi Perekonomian
Badan Siber dan Sandi Negara
Jl. Raya Muchtar No.70, Bojongsari Lama, Kec. Bojongsari, Kota Depok,
Jawa Barat 16516
Email : kamsisan.esda@bssn.go.id